

Sicurezza

CdL in Informatica – L31

Lezione 2 – Cryptographic Tools

Prof. Emiliano Casalicchio

Department of Computer Science

Sapienza University of Rome



SAPIENZA
UNIVERSITÀ DI ROMA



Chapter 2

Cryptographic Tools

Topics

- Confidentiality with symmetric encryption
- Message authentication and hash functions
- Public key encryption
- Digital signature and key management
- Random and pseudorandom numbers

Symmetric Encryption

- The universal technique for providing confidentiality for transmitted or stored data
- Also referred to as conventional encryption or single-key encryption
- Two requirements for secure use:
 - Need a strong encryption algorithm
 - Sender and receiver must have obtained copies of the secret key in a secure fashion and must keep the key secure

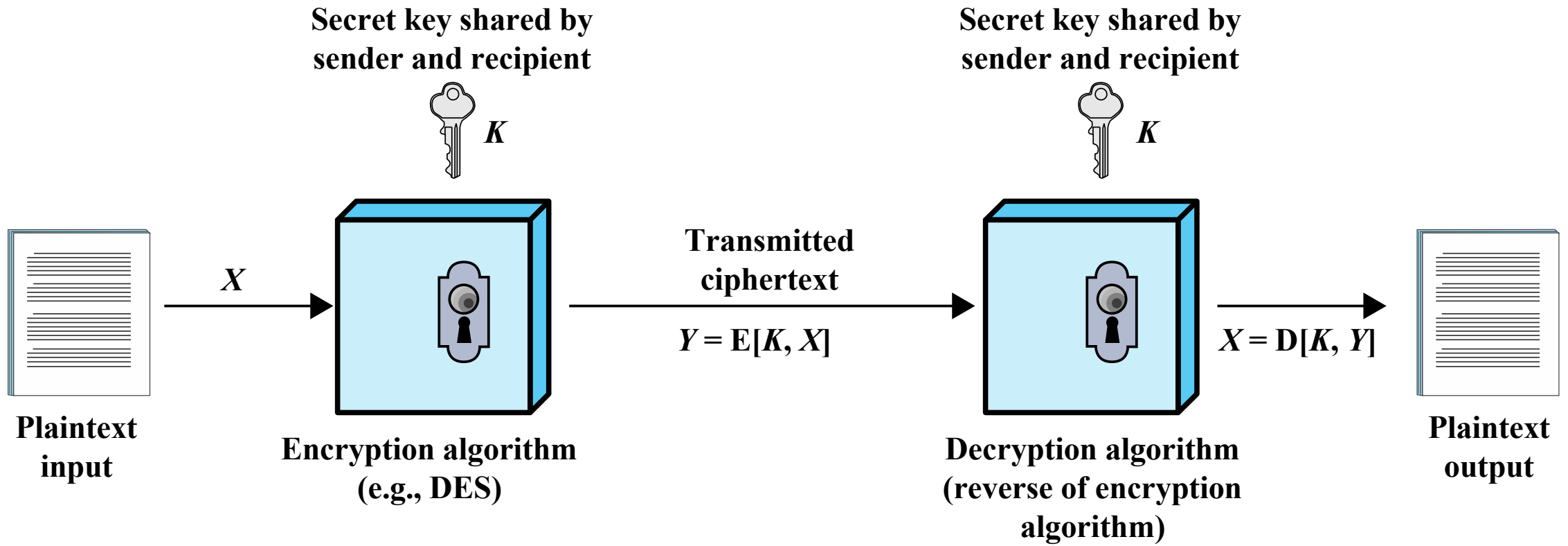


Figure 2.1 Simplified Model of Symmetric Encryption

Attacking Symmetric Encryption

Cryptanalytic Attacks (cryptanalysis)

- Rely on:
 - Nature of the algorithm
 - Some knowledge of the general characteristics of the plaintext
 - Some sample plaintext-ciphertext pairs
- Exploits the characteristics of the algorithm to attempt to deduce a specific plaintext or the key being used
 - If successful all future and past messages encrypted with that key are compromised

Attacking Symmetric Encryption

Brute-Force Attacks

- Try all possible keys on some ciphertext until an intelligible translation into plaintext is obtained
 - On average half of all possible keys must be tried to achieve success

Data Encryption Standard (DES)

- Until recently was the most widely used encryption scheme
 - Referred to as the Data Encryption Algorithm (DEA)
 - Uses 64 bit plaintext block and 56 bit key to produce a 64 bit ciphertext block
- Strength concerns:
 - Concerns about the algorithm itself
 - DES is the most studied encryption algorithm in existence
 - Concerns about the use of a 56-bit key
 - The speed of commercial off-the-shelf processors makes this key length woefully inadequate

Triple DES (3DES)

- Repeats basic DES algorithm three times using either two or three unique keys
- First standardized for use in financial applications in ANSI standard X9.17 in 1985
- Attractions:
 - 168-bit key length overcomes the vulnerability to brute-force attack of DES
 - Underlying encryption algorithm is the same as in DES
- Drawbacks:
 - Algorithm is sluggish in software
 - Uses a 64-bit block size

Advanced Encryption Standard (AES)

**Needed a replacement
for 3DES**

**3DES was not
reasonable for long
term use**

**NIST called for
proposals for a new
AES in 1997**

**Should have a security strength
equal to or better than 3DES**

Significantly improved efficiency

Symmetric block cipher

**128 bit data and 128/192/256 bit
keys**

**Selected Rijndael in
November 2001**

**Published as
FIPS 197**

Comparison of Three Popular Symmetric Encryption Algorithms

	DES	Triple DES	AES
Plaintext block size (bits)	64	64	128
Ciphertext block size (bits)	64	64	128
Key size (bits)	56	112 or 168	128, 192, or 256

DES = Data Encryption Standard

AES = Advanced Encryption Standard

Most commonly used symmetric encryption algorithms are block ciphers.

A block cipher processes the plaintext input in fixed-size blocks and produces a block of ciphertext of equal size for each plaintext block

Average Time Required for Exhaustive Key Search

Key size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 decryptions/s	Time Required at 10^{13} decryptions/s
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	2^{55} ns = 1.125 years	1 hour
128	AES	$2^{128} \approx 3.4 \times 10^{38}$	2^{127} ns = 5.3×10^{21} years	5.3×10^{17} years
168	Triple DES	$2^{168} \approx 3.7 \times 10^{50}$	2^{167} ns = 5.8×10^{33} years	5.8×10^{29} years
192	AES	$2^{192} \approx 6.3 \times 10^{57}$	2^{191} ns = 9.8×10^{40} years	9.8×10^{36} years
256	AES	$2^{256} \approx 1.2 \times 10^{77}$	2^{255} ns = 1.8×10^{60} years	1.8×10^{56} years

Notes

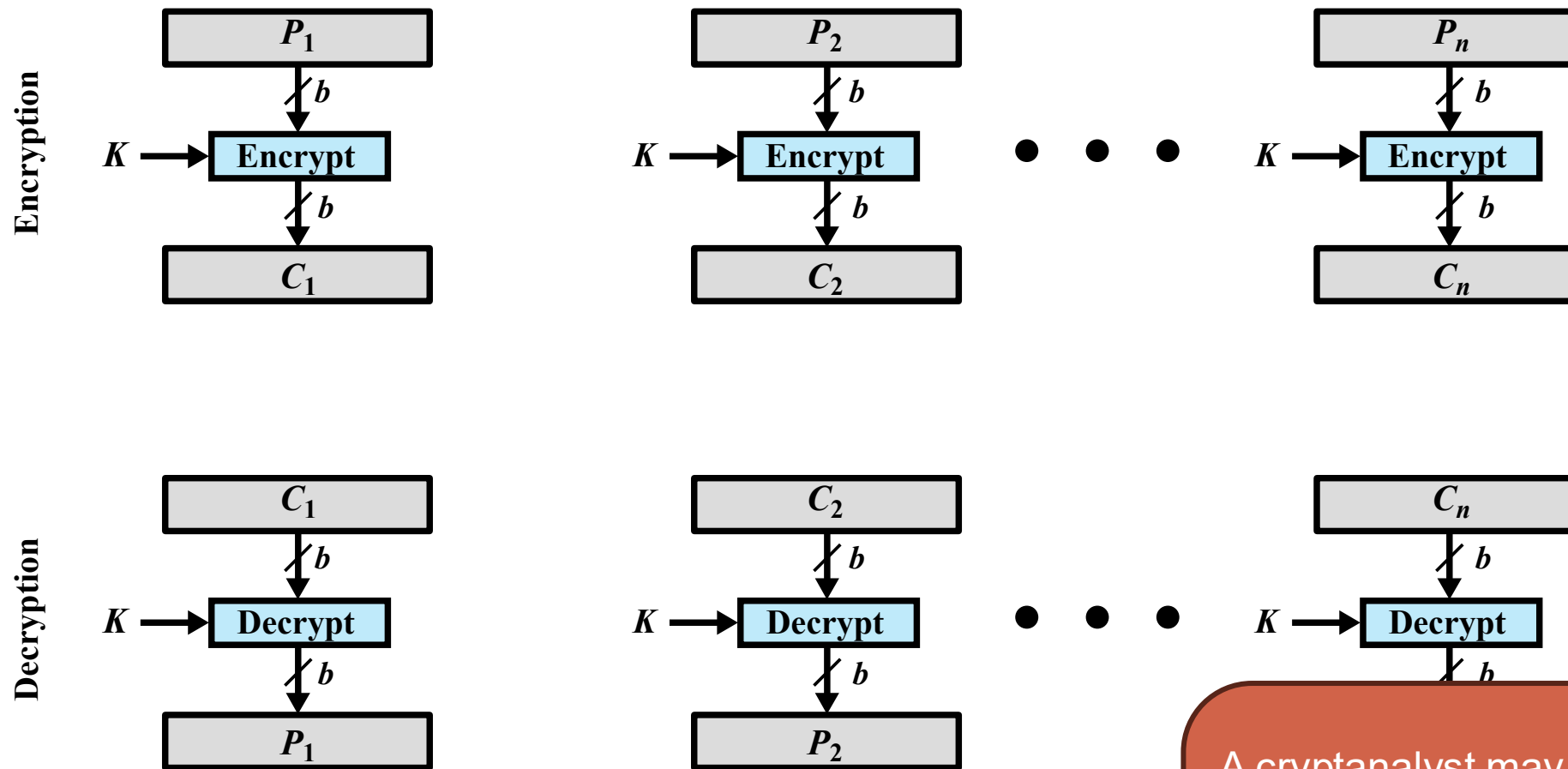
All the numbers in the previous table depends on decryption/s (methods and processor speed)

Today we talk about quantum-resistant cryptographic algorithms (usually public-key algorithms)

1. To be secure against a cryptanalytic attack by a quantum computer.
2. PK rely on the difficulty of one of three mathematical problems: the integer factorization problem, the discrete logarithm problem or the elliptic-curve discrete logarithm problem
3. QC can easily solved this problems

Practical Security Issues

- Typically symmetric encryption is applied to a unit of data larger than a single 64-bit or 128-bit block
- Electronic codebook (ECB) mode is the simplest approach to multiple-block encryption
 - Each block of plaintext is encrypted using the same key



(a) Block cipher encryption (electronic codebook mode)

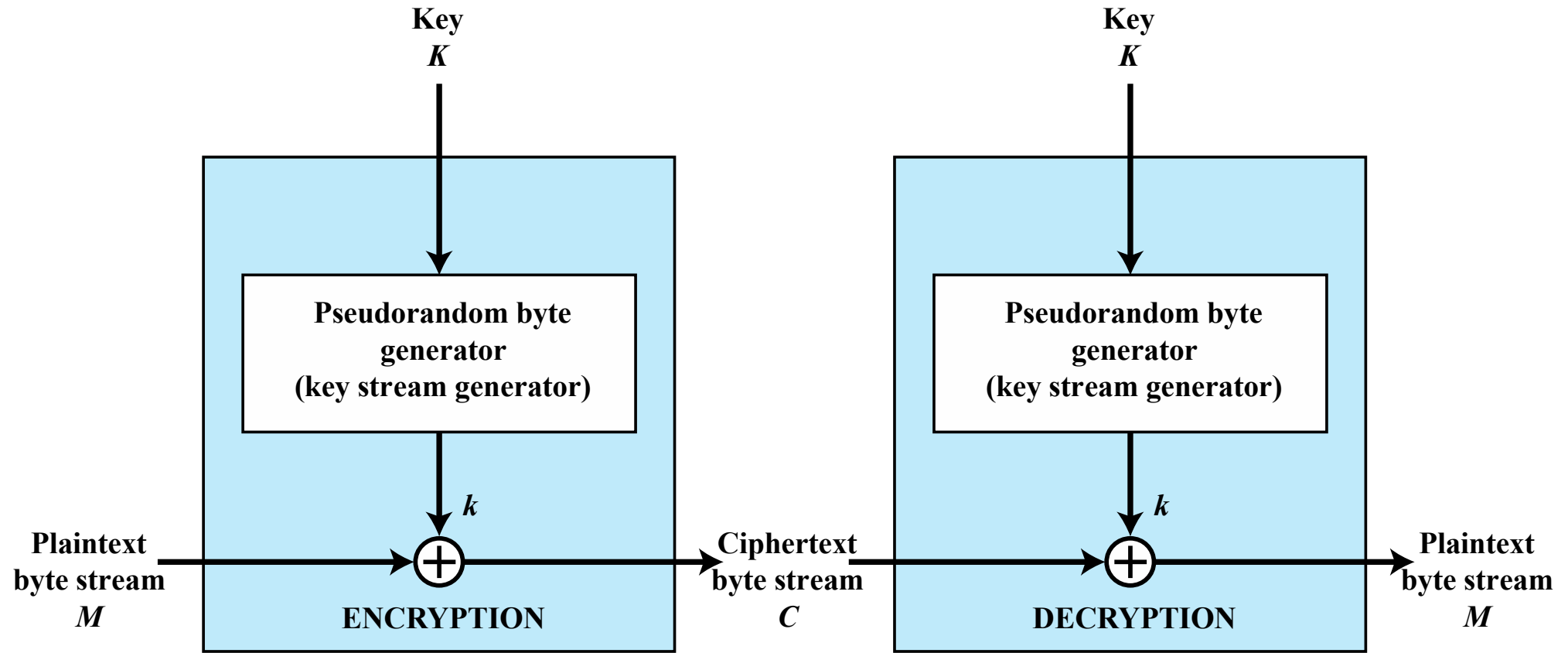
A cryptanalyst may exploit regularities in the plaintext. For example, if it is known that the message always starts out with certain predefined fields, then the cryptanalyst may have a number of known plaintext-ciphertext pairs with which to work.

Practical Security Issues (cont'd)

- Modes of operation
 - Alternative techniques developed to increase the security of symmetric block encryption for large sequences
 - Overcomes the weaknesses of ECB

Types of Symmetric Encryption

- Block cipher encryption (de-)
- Stream cipher encryption (de-)



(b) Stream encryption

Block & Stream Ciphers

Block Cipher

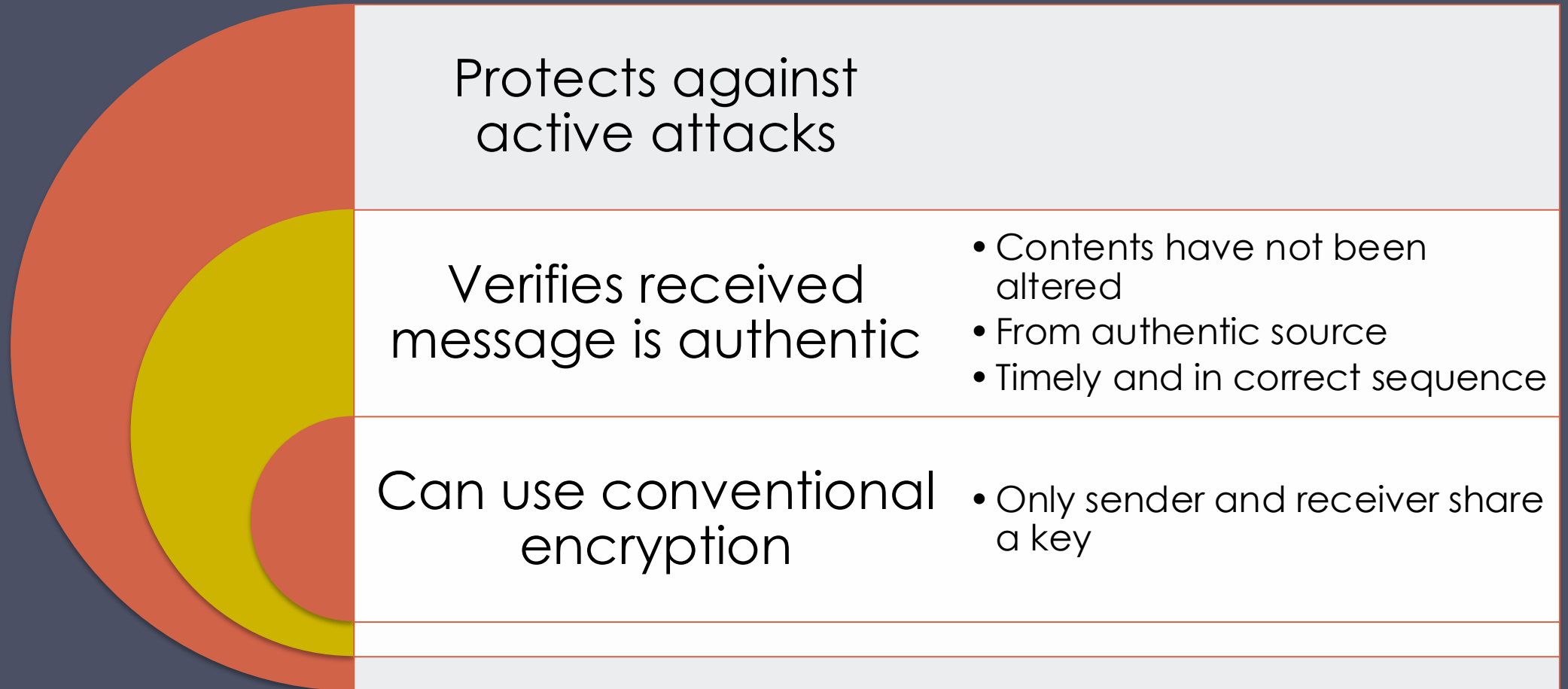
- Processes the input one block of elements at a time
- Produces an output block for each input block
- Can reuse keys
- More common

Stream Cipher

- Processes the input elements continuously
- Produces output one element at a time
- Primary advantage is that they are almost always faster and use far less code
- Encrypts plaintext one byte at a time
- Pseudorandom stream is one that is unpredictable without knowledge of the input key

- Encryption protect against passive attacks (eavesdropping)
- How to protect against active attacks (falsification of data and transactions) ?

Message Authentication



Message authentication

- Without confidentiality
 - The message is authenticated but not encrypted
 - A message tag (authentication tag) is produced and added to the message
- With confidentiality
 - The message is authenticated and encrypted
 - The message and the auth tag are encrypted
- Typically message authentication is provided as a separate function from message encryption

Message Authentication Without Confidentiality

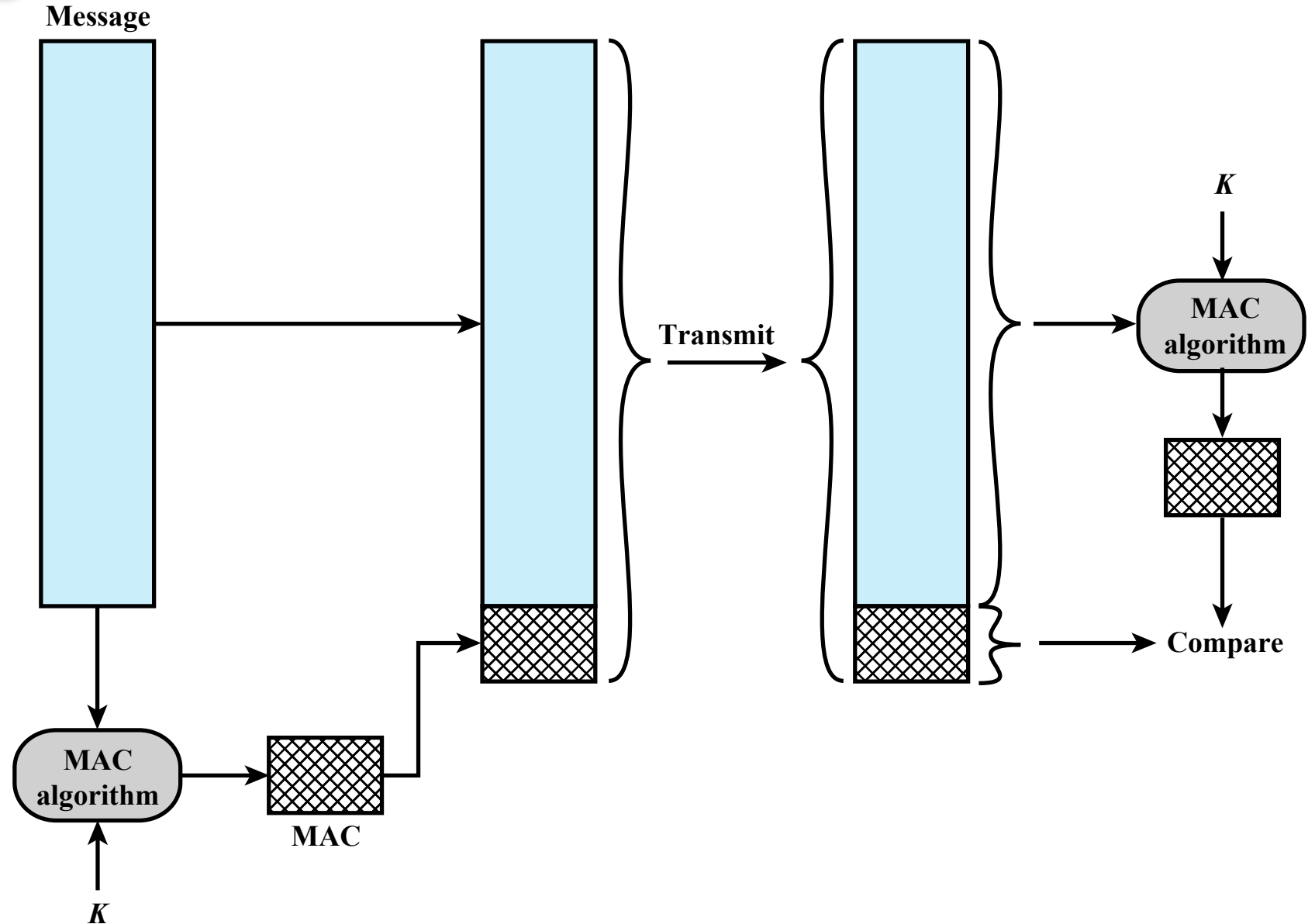
- Situations in which message authentication without confidentiality may be preferable include:
 - Applications in which the same message is broadcast to a number of destinations
 - An exchange in which one side has a heavy load and cannot afford the time to decrypt all incoming messages
 - Authentication of a computer program in plaintext is an attractive service
- Thus, there is a place for both authentication and encryption in meeting security requirements

Message Authentication Code

MAC: Message
Authentication Code

K: Secret Key e.g. shared
between A and B

$MAC_M = F(K_{AB}, M)$.



MAC: Assumption and Assurance

- Assumption:
 - Only the receiver and the sender know the identity of the secret key
- Receiver's Assurance (if the calculated code matches)
 - the message has not been altered. If an attacker alters the message but does not alter the code, then the receiver's calculation of the code will differ from the received code. Because the assumption, the attacker cannot alter the code
 - the message is from the alleged sender. Because the assumption, no one else knows the secret key, no one else could prepare a message with a proper code
 - If the message includes a sequence number (such as is used with X.25, HDLC, and TCP), then the receiver can be assured of the proper sequence, because an attacker cannot successfully alter the sequence number

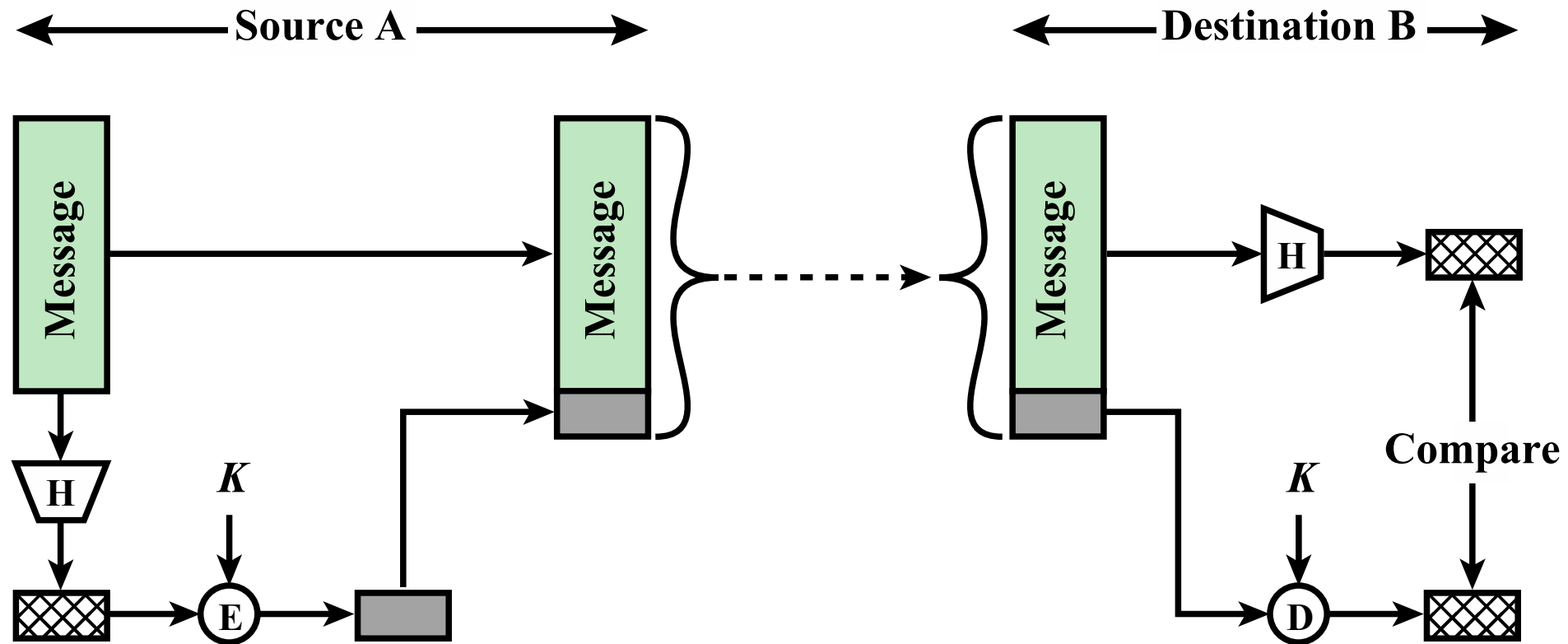
One-Way Hash Functions

- Alternative to MAC
- Does not require an input key
 - accepts a variable-size message M as input and produces a fixed-size message digest $H(M)$ as output

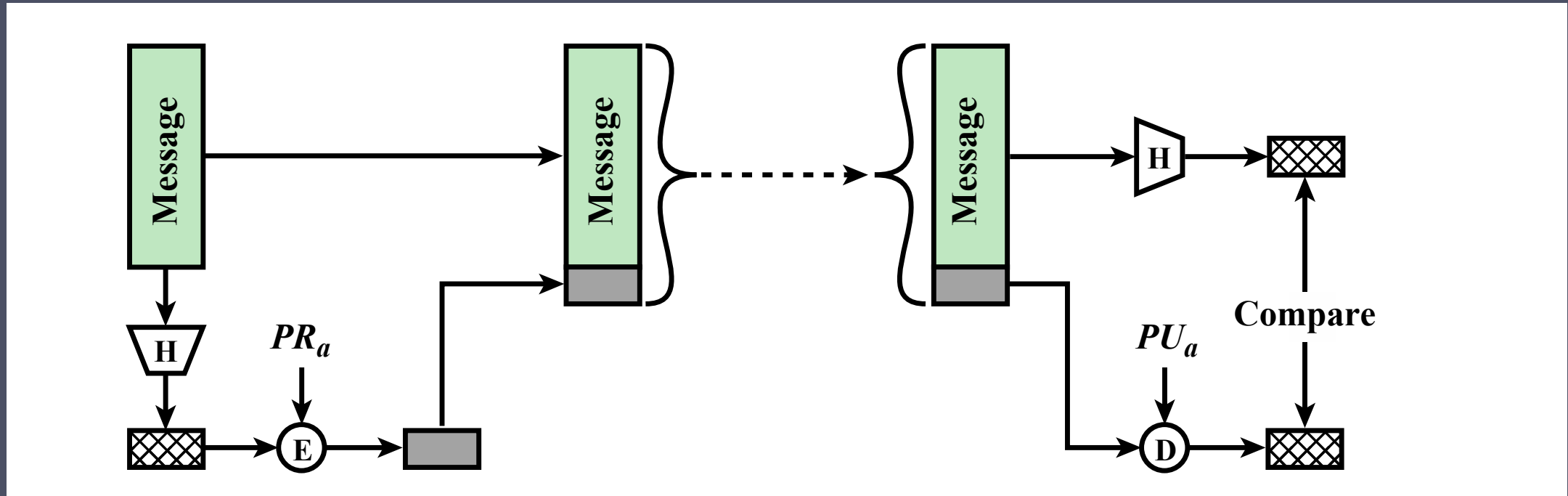


- The message is padded out to an integer multiple of some fixed length (e.g., 1024 bits)
- The padding includes the value of the length of the original message in bits
- The length field is a security measure to increase the difficulty for an attacker to produce an alternative message with the same hash value

Message Auth using one-way Hash function + Symmetric Encryption

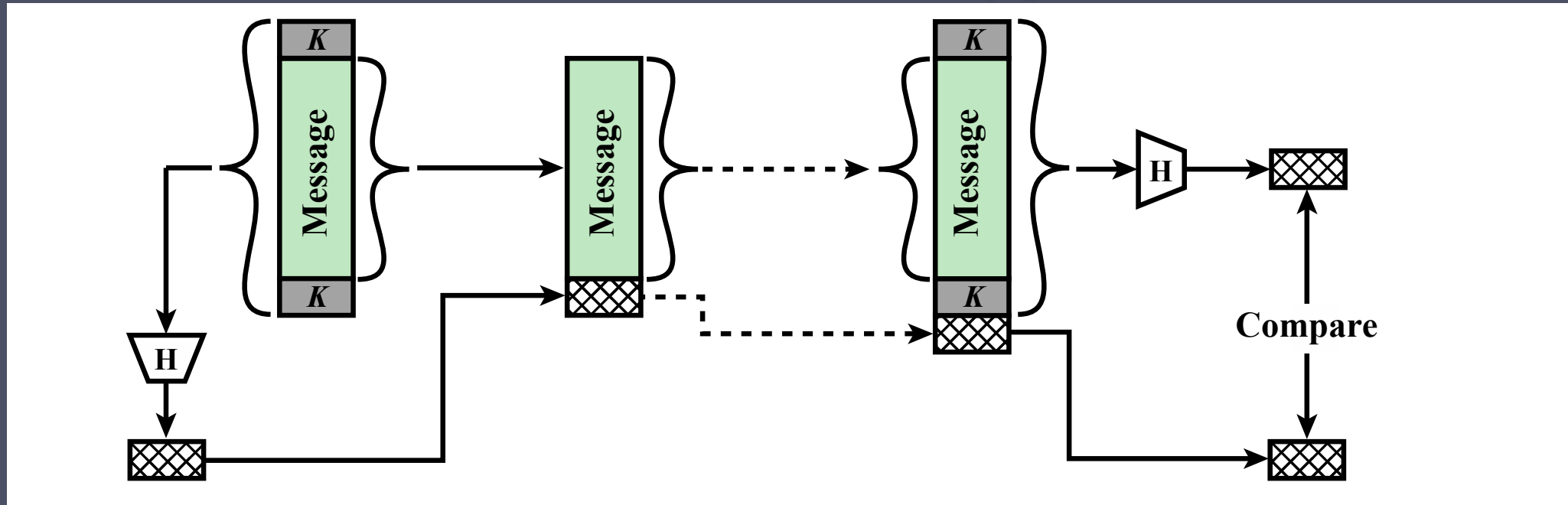


Message Auth using one-way Hash function + Public Key Encryption



- It provides a digital signature as well as message authentication
- it does not require the distribution of keys to communicating parties.

Message Auth using one-way Hash function + Secret Value (no encryption)



- Encryption software is quite slow
- Encryption hardware costs are non-negligible
- Sender: computes $MD_M = H(K \parallel M \parallel K)$; sends $[MD_M \parallel M]$
- Receiver: knows K ; recompute $H(K \parallel M \parallel K)$; verify MD_M

Properties of a secure hash function H

Weak Hash Function

Strong Hash Function

1. Can be applied to a block of data of any size
2. Produces a fixed-length output
3. $H(x)$ is relatively easy to compute for any given x , making both hardware and software implementations practical
4. Is **One-way or preimage resistant**
 - For any given code h , it is computationally infeasible to find x such that $H(x)=h$
5. Is **Second preimage of Weak Collision resistant**
 - For any given block x , it is computationally infeasible to find $y \neq x$ with $H(y)=H(x)$.
6. Is **strong collision resistant**
 - It is computationally infeasible to find any pair (x, y) such that $H(x) = H(y)$.

One-way / preimage resistant

- If it is easy to find $x=H^{-1}(h)$ a schema like Message Auth with secret value can be broken as follows
- The attacker
 - can observe or intercept a transmission
 - obtains the message M and the hash code $MD_M = H(K \parallel M \parallel K)$
 - Inverts the hash function $K \parallel M \parallel K = H^{-1}(MD_M)$
 - Easy to compute K because it knows M

Weak collision / second preimage resistant

- This prevents forgery when an encrypted hash code is used
 - E.g. Message Auth with Private or Public Encryption
- If the hash is not weak collision resistant the attacker can
 1. observe or intercept a message plus its encrypted hash code
 2. generate an unencrypted hash code from the message
 3. generate an alternate message with the same hash code

Strong collision resistant

- It protects against the following kind of attacks
 1. Bob sends Alice a message to pay a small amount of money
 2. Alice signs the document (acknowledge the message)
 3. Bob finds two messages with the same hash, one of which requires Alice to pay a small amount and one that requires a large payment.
 4. Alice signed the first message and Bob is then able to claim that the second message is authentic

Security of Hash Functions

There are two approaches to attacking a secure hash function:

Cryptanalysis

- Exploit logical weaknesses in the algorithm

Brute-force attack

- Strength of hash function depends solely on the length of the hash code produced by the algorithm

SHA most widely used hash algorithm

Additional secure hash function applications:

Passwords

- Hash of a password is stored by an operating system

Intrusion detection

- Store $H(F)$ for each file on a system and secure the hash values

Public-Key Encryption Structure

Publicly
proposed by
Diffie and
Hellman in
1976

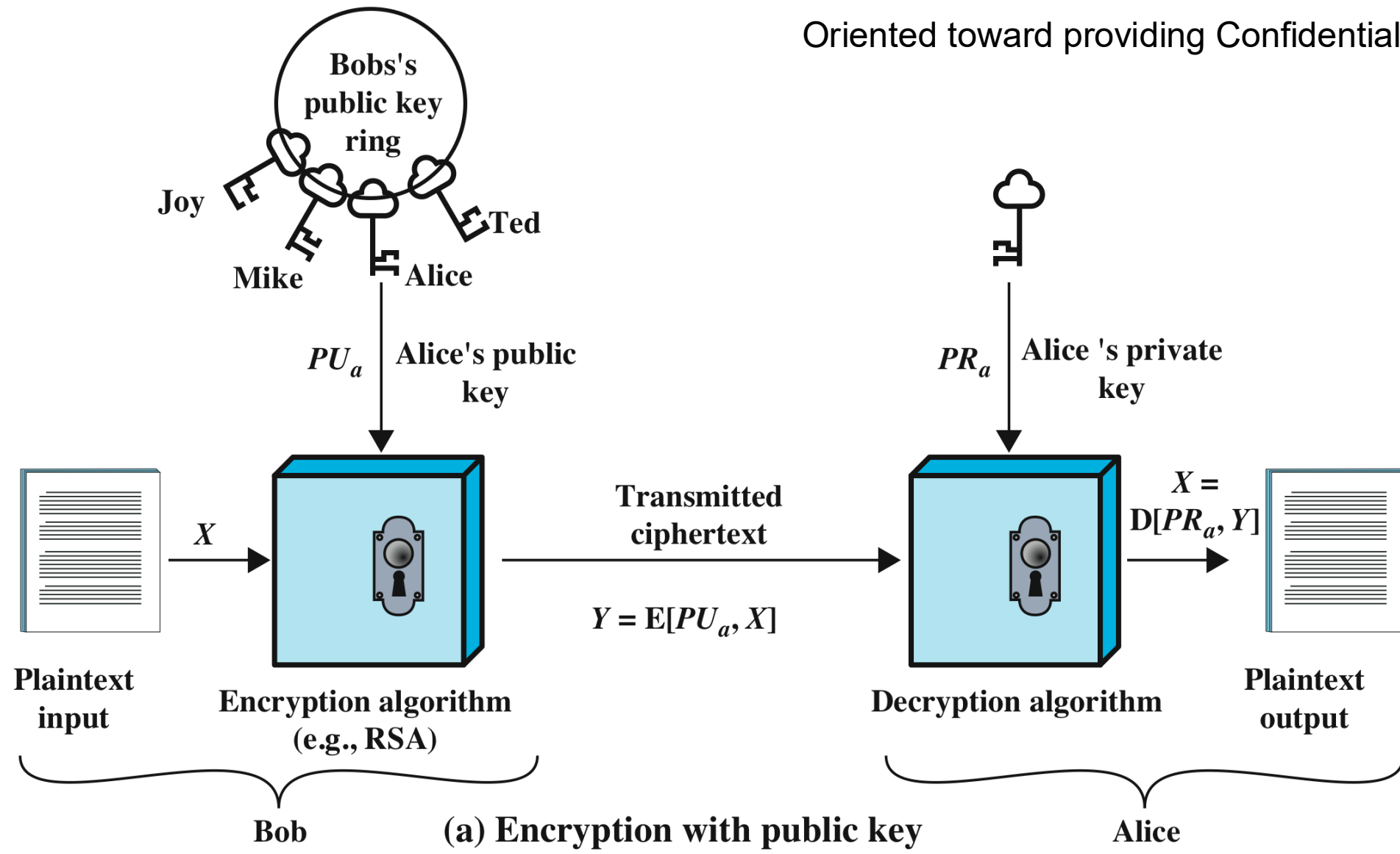
Based on
mathematical
functions

Asymmetric

- Uses two separate keys
- Public key and private key
- Public key is made public for others to use

Some form of
protocol is
needed for
distribution

Oriented toward providing Confidentiality



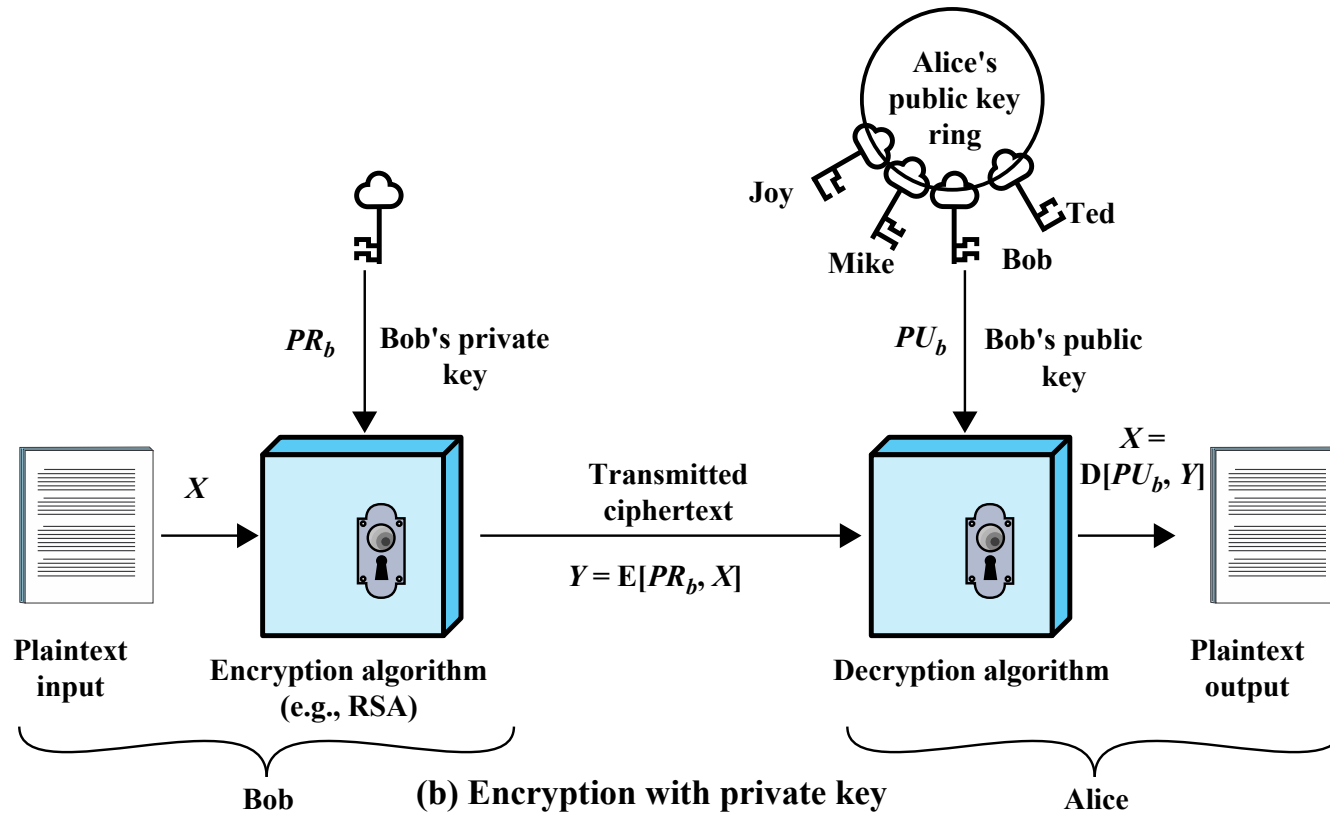


Figure 2.6 Public-Key Cryptography

- User encrypts data using his or her own private key
- Anyone who knows the corresponding public key will be able to decrypt the message
- What can we get from this use of Public-key Encryption?
 - Authentication or data integrity

Asymmetric Encryption Algorithms

- RSA (Rivest, Shamir, Adleman), 1977
 - Most widely accepted and implemented approach to public-key encryption
 - Block cipher in which the plaintext and ciphertext are integers between 0 and $n-1$ for some n
- Diffie-Hellman key exchange algorithm 1976
 - Enables two users to generate a shared secret that can be used as a secret key for subsequent symmetric encryption of messages
 - Limited to the exchange of the keys
- Digital Signature Standard (DSS)
 - Provides only a digital signature function with SHA-1
 - Cannot be used for encryption or key exchange
- Elliptic curve cryptography (ECC)
 - Security like RSA, but with much smaller keys

Applications for Public-Key Cryptosystems

public-key cryptosystems categories



Algorithm	Digital Signature	Symmetric Key Distribution	Encryption of Secret Keys
RSA	Yes	Yes	Yes
Diffie-Hellman	No	Yes	No
DSS	Yes	No	No
Elliptic Curve	Yes	Yes	Yes

Requirements public key cryptography [Diffie and Helman 1976]

- Computationally easy for a party B to generate $\mathbf{PU}_B, \mathbf{PR}_B$
- Computationally easy for a sender A knowing M and $\mathbf{PU}_B$ to generate $\mathbf{C}=\mathbf{E}(\mathbf{PU}_B, \mathbf{M})$
- Computationally easy for the receiver to decrypt: $\mathbf{M}=\mathbf{D}(\mathbf{PR}_B, \mathbf{C})=(\mathbf{PR}_B, \mathbf{E}(\mathbf{PU}_B, \mathbf{M}))$
- Computational infeasible for an opponent knowing $\mathbf{PU}_B$ to determine $\mathbf{PR}_B$
- Computational infeasible for an opponent knowing $\mathbf{PU}_B$ and C to recover M
- Both PR and PU can be used for encryption/decryption (useful but not necessary)
 - $\mathbf{M}=\mathbf{D}[\mathbf{PU}_B, \mathbf{E}(\mathbf{PR}_B, \mathbf{M})] = \mathbf{D}[\mathbf{PR}_B, \mathbf{E}(\mathbf{PU}_B, \mathbf{M})]$

